



Threagile

Agile Threat Modeling

Threat Model Report

VaultNote Threat Model

18 April 2026

VaultNote Security Team

Table of Contents

Results Overview

Management Summary	4
Impact Analysis of 12 Initial Risks in 5 Categories	5
Risk Mitigation	6
Asset Register	7
Impact Analysis of 12 Remaining Risks in 5 Categories	10
Application Overview	11
Data-Flow Diagram	12
Security Requirements	13
Abuse Cases	14
Tag Listing	15
STRIDE Classification of Identified Risks	17
Assignment by Function	19
RAA Analysis	20
Data Mapping	21
Out-of-Scope Assets: 0 Assets	22
Potential Model Failures: 0 / 0 Risks	23
Questions: 0 / 0 Questions	24

Risks by Vulnerability category

Identified Risks by Vulnerability category	25
Data Disclosure - Personal Data Transmitted Over Unencrypted Channel: 2 / 2 Risks	26
Detectability - PII Flows Without Audit Logging: 2 / 2 Risks	28
Non-Repudiation - PII or Auth Tokens Accessible in Browser-Side Storage: 1 / 1 Risk	30
Unawareness - PII Processed Without a Consent Management Component: 1 / 1 Risk	33
Linkability - Same PII Data Asset Processed Across Multiple Trust Boundaries: 6 / 6 Risks	35

Risks by Technical Asset

Identified Risks by Technical Asset	38
API Server: 3 / 3 Risks	39
Browser SPA: 3 / 3 Risks	43
Nginx Reverse Proxy: 3 / 3 Risks	46
MinIO Object Storage: 1 / 1 Risk	49
PostgreSQL Database: 1 / 1 Risk	51
Redis Cache: 1 / 1 Risk	53

Data Breach Probabilities by Data Asset

Identified Data Breach Probabilities by Data Asset	55
File Attachments: 10 / 10 Risks	56
Note Content: 10 / 10 Risks	57
Session Tokens: 4 / 4 Risks	58
User Credentials: 10 / 10 Risks	59

Trust Boundaries

Application Network	60
Data Tier	60
DMZ	60
Internet	60

Shared Runtime

Docker Host	62
-------------	----

About Threagile

Risk Rules Checked by Threagile	63
Disclaimer	64

Management Summary

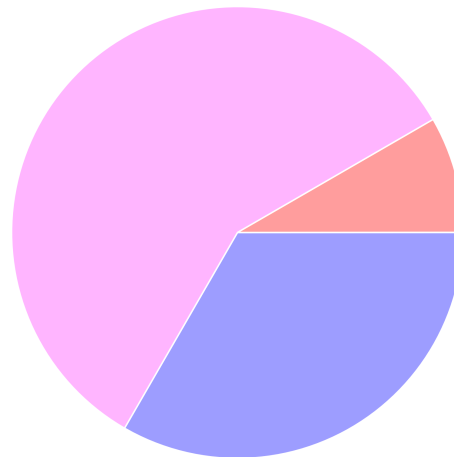
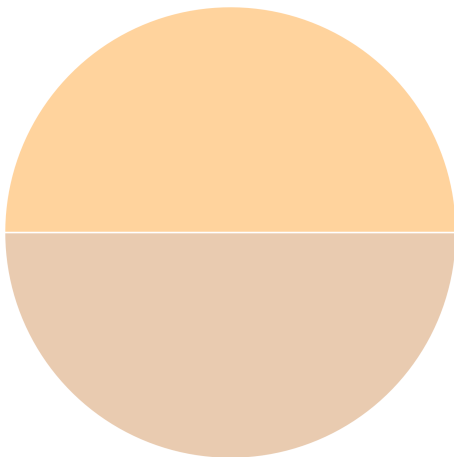
Threagile toolkit was used to model the architecture of "VaultNote Threat Model" and derive risks by analyzing the components and data flows. The risks identified during this analysis are shown in the following chapters. Identified risks during threat modeling do not necessarily mean that the vulnerability associated with this risk actually exists: it is more to be seen as a list of potential risks and threats, which should be individually reviewed and reduced by removing false positives. For the remaining risks it should be checked in the design and implementation of "VaultNote Threat Model" whether the mitigation advices have been applied or not.

Each risk finding references a chapter of the OWASP ASVS (Application Security Verification Standard) audit checklist. The OWASP ASVS checklist should be considered as an inspiration by architects and developers to further harden the application in a Defense-in-Depth approach. Additionally, for each risk finding a link towards a matching OWASP Cheat Sheet or similar with technical details about how to implement a mitigation is given.

In total **12 initial risks** in **5 categories** have been identified during the threat modeling process:

0 critical risk
0 high risk
6 elevated risk
6 medium risk
0 low risk

1 unchecked
0 in discussion
7 accepted
4 in progress
0 mitigated
0 false positive



VaultNote is a containerized note-taking application comprised of a React SPA, Nginx reverse proxy, Node.js/Express REST API, PostgreSQL database, Redis session store, and MinIO object storage. The architecture deliberately contains several intentional misconfigurations (unencrypted internal HTTP, no encryption at rest, hardcoded credentials) to demonstrate automated threat detection via Threagile. All findings below are expected and serve as demonstration targets.

Impact Analysis of 12 Initial Risks in 5 Categories

The most prevalent impacts of the **12 initial risks** (distributed over **5 risk categories**) are (taking the severity ratings into account and using the highest for each category):

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated: **Data Disclosure - Personal Data Transmitted Over Unencrypted Channel**: 2 Initial Risks - Exploitation likelihood is *Likely with High* impact.

Exposure of personal data to eavesdroppers, potential data breach notification obligations under GDPR Article 33, and significant regulatory penalties.

Elevated: **Detectability - PII Flows Without Audit Logging**: 2 Initial Risks - Exploitation likelihood is *Likely with Medium* impact.

Inability to detect unauthorized access to personal data, failure to meet GDPR accountability obligations, and potential inability to meet breach notification deadlines.

Elevated: **Non-Repudiation - PII or Auth Tokens Accessible in Browser-Side Storage**: 1 Initial Risk - Exploitation likelihood is *Likely with Medium* impact.

Stolen session tokens allow account takeover and impersonation. The original user cannot repudiate actions performed by the attacker. Stolen PII violates GDPR data minimisation and storage limitation principles.

Elevated: **Unawareness - PII Processed Without a Consent Management Component**: 1 Initial Risk - Exploitation likelihood is *Likely with Medium* impact.

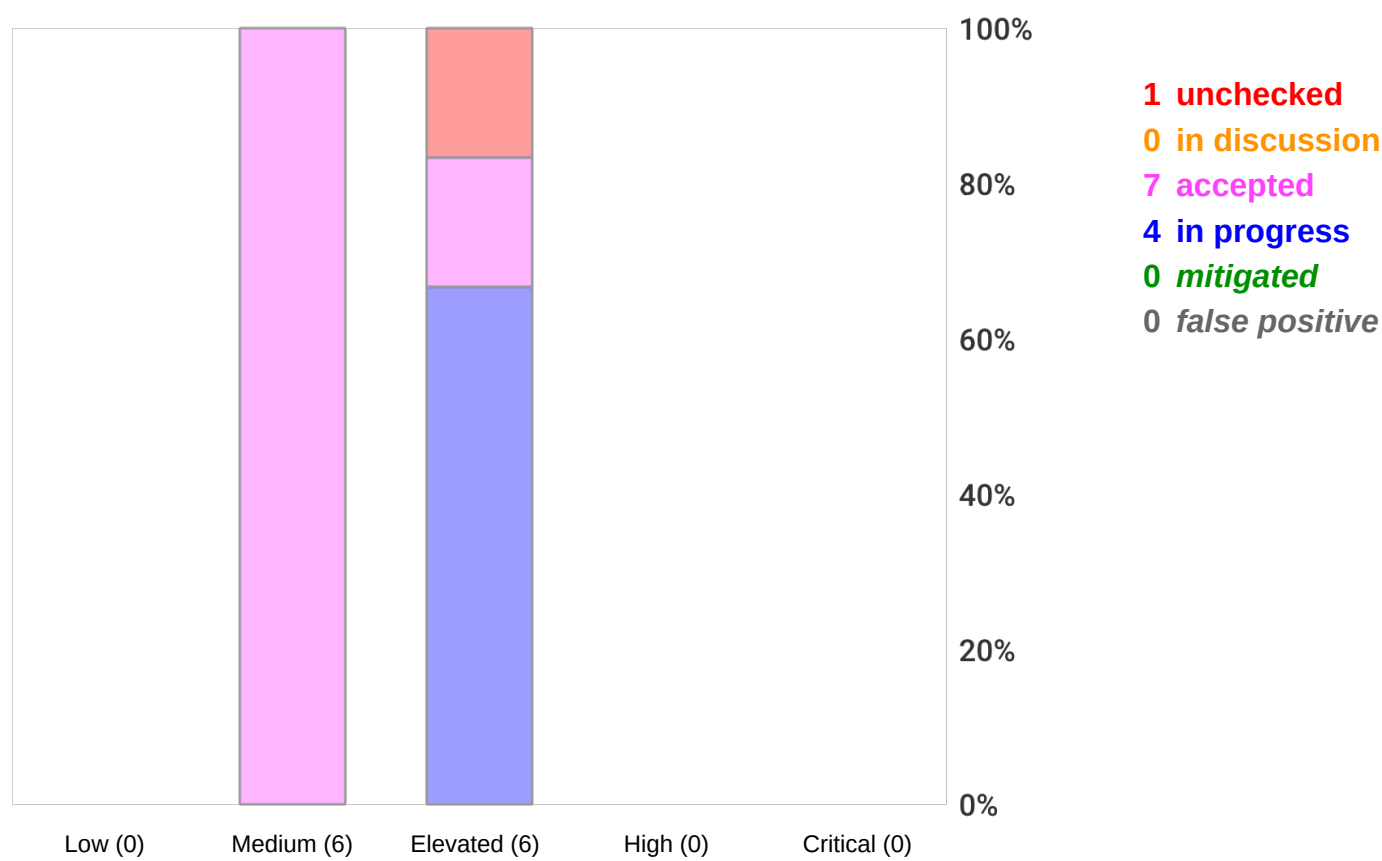
Data subjects cannot exercise GDPR rights. Regulatory investigation risk and class-action exposure in jurisdictions with private right of action.

Medium: **Linkability - Same PII Data Asset Processed Across Multiple Trust Boundaries**: 6 Initial Risks - Exploitation likelihood is *Unlikely with Medium* impact.

Aggregation of personal data enables profiling, re-identification, and violations of GDPR data minimisation and purpose limitation principles (Articles 5(1)(b) and 5(1)(c)).

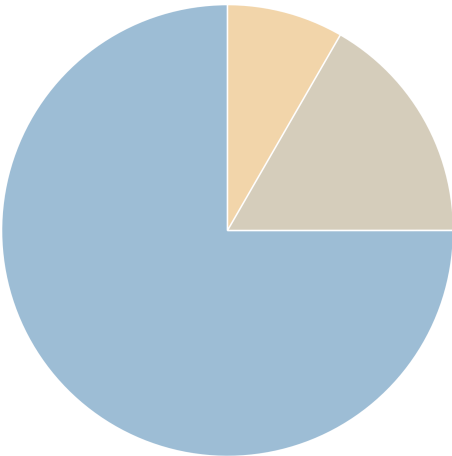
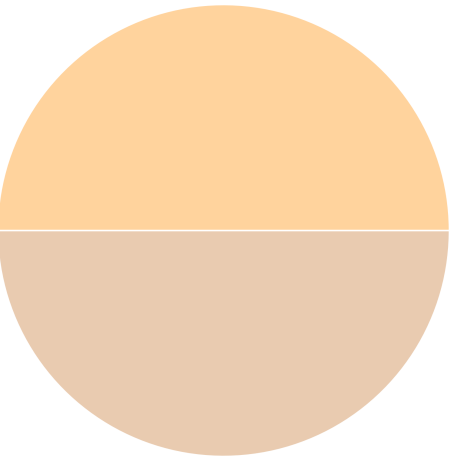
Risk Mitigation

The following chart gives a high-level overview of the risk tracking status (including mitigated risks):



After removal of risks with status *mitigated* and *false positive* the following 12 remain unmitigated:

- 0 unmitigated critical risk
 - 0 unmitigated high risk
 - 6 unmitigated elevated risk
 - 6 unmitigated medium risk
 - 0 unmitigated low risk
- 0 business side related
 - 9 architecture related
 - 1 development related
 - 2 operations related



Asset Register

Technical Assets

API Server

Node.js/Express REST API. Handles authentication (JWT/bcrypt), CRUD on notes, file uploads to MinIO. Bridges the frontend and backend networks. Single most security-critical component — compromise equals full data access.

Browser SPA

React Single Page Application served from Nginx. Users authenticate, manage notes, and upload files through this interface.

MinIO Object Storage

S3-compatible object store for file attachments. INTENTIONAL MISCONFIGURATION: Uses default minioadmin/minioadmin credentials (visible in docker-compose.yml) and stores files without encryption at rest. HTTP-only (no TLS) within the Docker network.

Nginx Reverse Proxy

Nginx terminates TLS and forwards all API traffic to the Express server over plain HTTP (port 3000). This is the DMZ entry point.

PostgreSQL Database

Primary relational datastore. Contains users table (email + bcrypt password hash), notes table (title + content), and attachments metadata. INTENTIONAL MISCONFIGURATION: No encryption at rest (encryption: none).

Redis Cache

In-memory store used as session store and JWT revocation list. INTENTIONAL MISCONFIGURATION: No encryption at rest. If Redis persistence is enabled and the RDB file is exfiltrated, session tokens are exposed.

Data Assets

File Attachments

Binary file uploads attached to notes. May include documents, images, or other sensitive files depending on note usage.

Note Content

User-authored note text — may include personal, financial, or health information depending on how users employ the application.

Session Tokens

JWT tokens and Redis session keys used to maintain authenticated state. Theft allows session hijacking without knowing the user's password.

User Credentials

Email addresses and bcrypt-hashed passwords used for authentication. Compromise allows full account takeover.

Impact Analysis of 12 Remaining Risks in 5 Categories

The most prevalent impacts of the **12 remaining risks** (distributed over **5 risk categories**) are (taking the severity ratings into account and using the highest for each category):

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated: **Data Disclosure - Personal Data Transmitted Over Unencrypted Channel: 2 Remaining Risks** - Exploitation likelihood is *Likely with High* impact.

Exposure of personal data to eavesdroppers, potential data breach notification obligations under GDPR Article 33, and significant regulatory penalties.

Elevated: **Detectability - PII Flows Without Audit Logging: 2 Remaining Risks** - Exploitation likelihood is *Likely with Medium* impact.

Inability to detect unauthorized access to personal data, failure to meet GDPR accountability obligations, and potential inability to meet breach notification deadlines.

Elevated: **Non-Repudiation - PII or Auth Tokens Accessible in Browser-Side Storage: 1 Remaining Risk** - Exploitation likelihood is *Likely with Medium* impact.

Stolen session tokens allow account takeover and impersonation. The original user cannot repudiate actions performed by the attacker. Stolen PII violates GDPR data minimisation and storage limitation principles.

Elevated: **Unawareness - PII Processed Without a Consent Management Component: 1 Remaining Risk** - Exploitation likelihood is *Likely with Medium* impact.

Data subjects cannot exercise GDPR rights. Regulatory investigation risk and class-action exposure in jurisdictions with private right of action.

Medium: **Linkability - Same PII Data Asset Processed Across Multiple Trust Boundaries: 6 Remaining Risks** - Exploitation likelihood is *Unlikely with Medium* impact.

Aggregation of personal data enables profiling, re-identification, and violations of GDPR data minimisation and purpose limitation principles (Articles 5(1)(b) and 5(1)(c)).

Application Overview

Business Criticality

The overall business criticality of "VaultNote Threat Model" was rated as:

(archive | operational | **IMPORTANT** | critical | mission-critical)

Business Overview

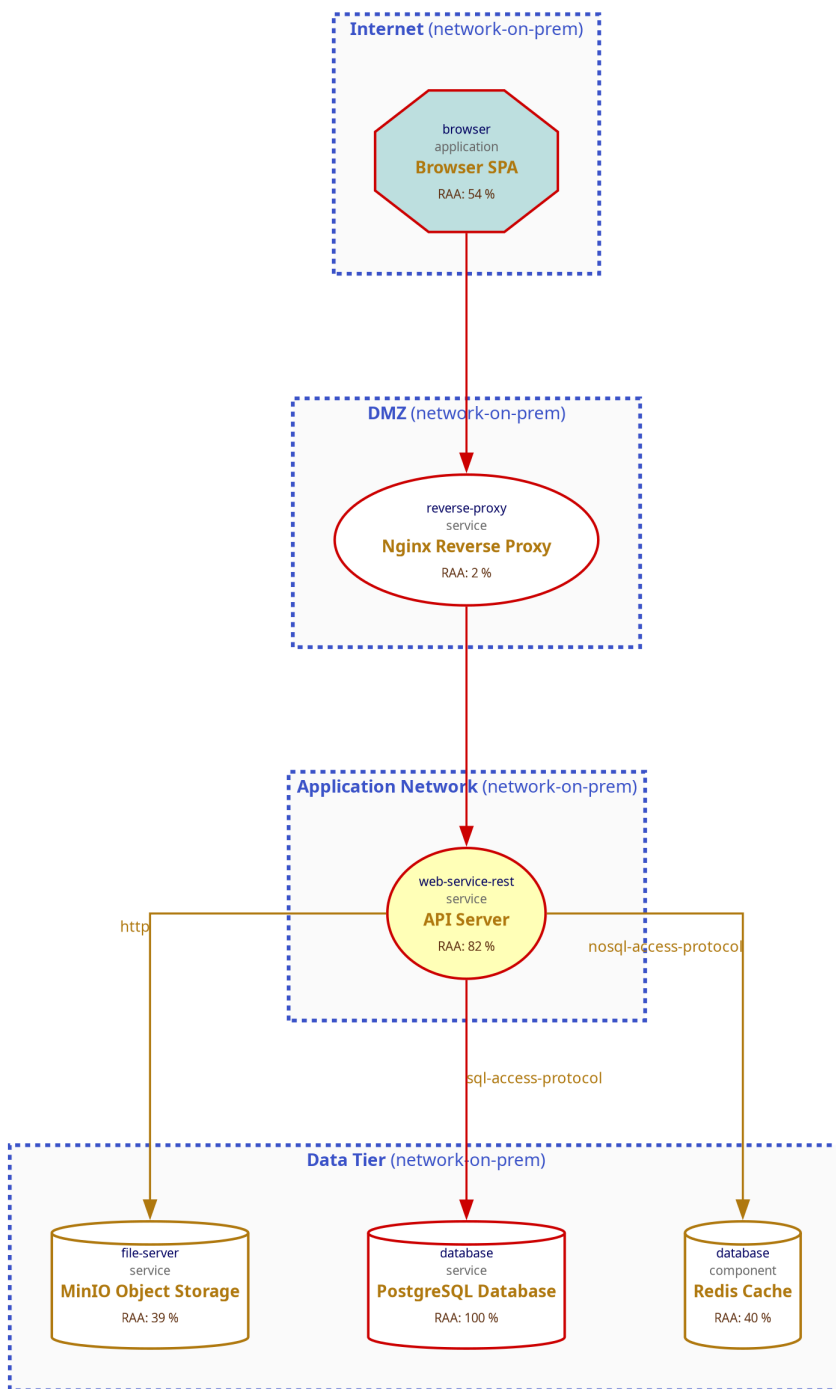
VaultNote allows authenticated users to create, edit, and share encrypted notes with file attachments. The application stores sensitive user data and note content that must be protected against unauthorized disclosure.

Technical Overview

Multi-tier containerized deployment: Nginx terminates TLS and proxies requests to the API over unencrypted HTTP. The API accesses PostgreSQL, Redis, and MinIO over plaintext TCP/HTTP within an internal Docker network.

Data-Flow Diagram

The following diagram was generated by Threagile based on the model input and gives a high-level overview of the data-flow between technical assets. The RAA value is the calculated *Relative Attacker Attractiveness* in percent. For a full high-resolution version of this diagram please refer to the PNG image file alongside this report.



Security Requirements

This chapter lists the custom security requirements which have been defined for the modeled target.

This list is not complete and regulatory or law relevant security requirements have to be taken into account as well. Also custom individual security requirements might exist for the project.

Abuse Cases

This chapter lists the custom abuse cases which have been defined for the modeled target.

This list is not complete and regulatory or law relevant abuse cases have to be taken into account as well. Also custom individual abuse cases might exist for the project.

Tag Listing

This chapter lists what tags are used by which elements.

cache

Redis Cache

container-runtime

Docker Host

docker

Docker Host

express

API Server

intentional-misconfiguration

MinIO File Storage, MinIO Object Storage, HTTP to API Server

jwt

API Server

minio

MinIO Object Storage

nginx

Nginx Reverse Proxy

nodejs

API Server

object-storage

MinIO Object Storage

postgresql

PostgreSQL Database

react

Browser SPA

redis

Redis Cache

relational

PostgreSQL Database

s3

MinIO Object Storage

session-store

Redis Cache

spa

Browser SPA

tls-termination

Nginx Reverse Proxy

STRIDE Classification of Identified Risks

This chapter clusters and classifies the risks by STRIDE categories: In total **12 potential risks** have been identified during the threat modeling process of which **0 in the Spoofing** category, **0 in the Tampering** category, **2 in the Repudiation** category, **10 in the Information Disclosure** category, **0 in the Denial of Service** category, and **0 in the Elevation of Privilege** category.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Spoofing

n/a

Tampering

n/a

Repudiation

Elevated: **Detectability - PII Flows Without Audit Logging: 2 / 2 Risks** - Exploitation likelihood is *Likely with Medium impact*.

Communication links that carry personal data without audit logging enabled mean that access to and use of personal data cannot be detected or reviewed after the fact. GDPR Article 5(2) requires demonstrable accountability.

Information Disclosure

Elevated: **Data Disclosure - Personal Data Transmitted Over Unencrypted Channel: 2 / 2 Risks** - Exploitation likelihood is *Likely with High impact*.

Personal data in transit over unencrypted communication links (plain HTTP, unencrypted database protocols, etc.) is exposed to network observers. GDPR Article 32 requires appropriate technical measures including encryption in transit.

Elevated: **Non-Repudiation - PII or Auth Tokens Accessible in Browser-Side Storage: 1 / 1 Risk** - Exploitation likelihood is *Likely with Medium impact*.

Browser-based clients (SPAs, web apps) that process personal data or authentication tokens typically persist them in localStorage or sessionStorage. This browser-accessible storage is readable by any JavaScript running in the same origin – including injected scripts. Without HttpOnly cookies or a strict Content-Security-Policy, the stored tokens and PII are one XSS payload away from full exfiltration. From a LINDDUN perspective this enables Non-Repudiation attacks: an adversary who steals a token can act as the victim, making it impossible to distinguish attacker actions from legitimate user actions in audit logs.

Elevated: Unawareness - PII Processed Without a Consent Management Component: 1 / 1 Risk - Exploitation likelihood is *Likely* with *Medium* impact.

When a system processes personal data from end users but has no consent-management technology in the architecture, data subjects are likely unaware of the nature and extent of processing. GDPR Articles 13 and 14 require transparent disclosure.

Medium: Linkability - Same PII Data Asset Processed Across Multiple Trust Boundaries: 6 / 6 Risks - Exploitation likelihood is *Unlikely* with *Medium* impact.

When the same personal-data asset is processed by technical assets in two or more different trust boundaries, an attacker who compromises any one boundary gains linkability across all others, enabling cross-context profiling.

Denial of Service

n/a

Elevation of Privilege

n/a

Assignment by Function

This chapter clusters and assigns the risks by functions which are most likely able to check and mitigate them: In total **12 potential risks** have been identified during the threat modeling process of which **0 should be checked by Business Side**, **9 should be checked by Architecture**, **1 should be checked by Development**, and **2 should be checked by Operations**.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Business Side

n/a

Architecture

Elevated: **Data Disclosure - Personal Data Transmitted Over Unencrypted Channel: 2 / 2 Risks** - Exploitation likelihood is *Likely with High impact*.

Migrate all communication links carrying PII data assets to TLS 1.2+ (preferably TLS 1.3). For internal service-to-service communication, consider mutual TLS (mTLS).

Elevated: **Unawareness - PII Processed Without a Consent Management Component: 1 / 1 Risk** - Exploitation likelihood is *Likely with Medium impact*.

Introduce a consent-manager (tagged with technology consent-manager) to capture, store, and honour data-subject preferences.

Medium: **Linkability - Same PII Data Asset Processed Across Multiple Trust Boundaries: 6 / 6 Risks** - Exploitation likelihood is *Unlikely with Medium impact*.

Use per-context pseudonyms or pairwise identifiers so the same natural person cannot be linked across trust boundaries.

Development

Elevated: **Non-Repudiation - PII or Auth Tokens Accessible in Browser-Side Storage: 1 / 1 Risk** - Exploitation likelihood is *Likely with Medium impact*.

Replace localStorage/sessionStorage token storage with HttpOnly, Secure, SameSite=Strict cookies. Cookies with the HttpOnly flag are inaccessible to JavaScript, eliminating the XSS token-theft vector. Deploy a strict Content-Security-Policy to limit damage from any residual XSS. Tag the asset has-httponly-session once deployed.

Operations

Elevated: **Detectability - PII Flows Without Audit Logging: 2 / 2 Risks** - Exploitation likelihood is *Likely with Medium impact*.

Set audit_logged to true on every communication link that transmits PII data assets. Store logs in a tamper-evident system separate from the application.

RAA Analysis

For each technical asset the **"Relative Attacker Attractiveness"** (RAA) value was calculated in percent. The higher the RAA, the more interesting it is for an attacker to compromise the asset. The calculation algorithm takes the sensitivity ratings and quantities of stored and processed data into account as well as the communication links of the technical asset. Neighbouring assets to high-value RAA targets might receive an increase in their RAA value when they have a communication link towards that target ("Pivoting-Factor").

The following lists all technical assets sorted by their RAA value from highest (most attacker attractive) to lowest. This list can be used to prioritize on efforts relevant for the most attacker-attractive technical assets:

Technical asset paragraphs are clickable and link to the corresponding chapter.

PostgreSQL Database: RAA 100%

Primary relational datastore. Contains users table (email + bcrypt password hash), notes table (title + content), and attachments metadata. INTENTIONAL MISCONFIGURATION: No encryption at rest (encryption: none).

API Server: RAA 82%

Node.js/Express REST API. Handles authentication (JWT/bcrypt), CRUD on notes, file uploads to MinIO. Bridges the frontend and backend networks. Single most security-critical component — compromise equals full data access.

Browser SPA: RAA 54%

React Single Page Application served from Nginx. Users authenticate, manage notes, and upload files through this interface.

Redis Cache: RAA 40%

In-memory store used as session store and JWT revocation list. INTENTIONAL MISCONFIGURATION: No encryption at rest. If Redis persistence is enabled and the RDB file is exfiltrated, session tokens are exposed.

MinIO Object Storage: RAA 39%

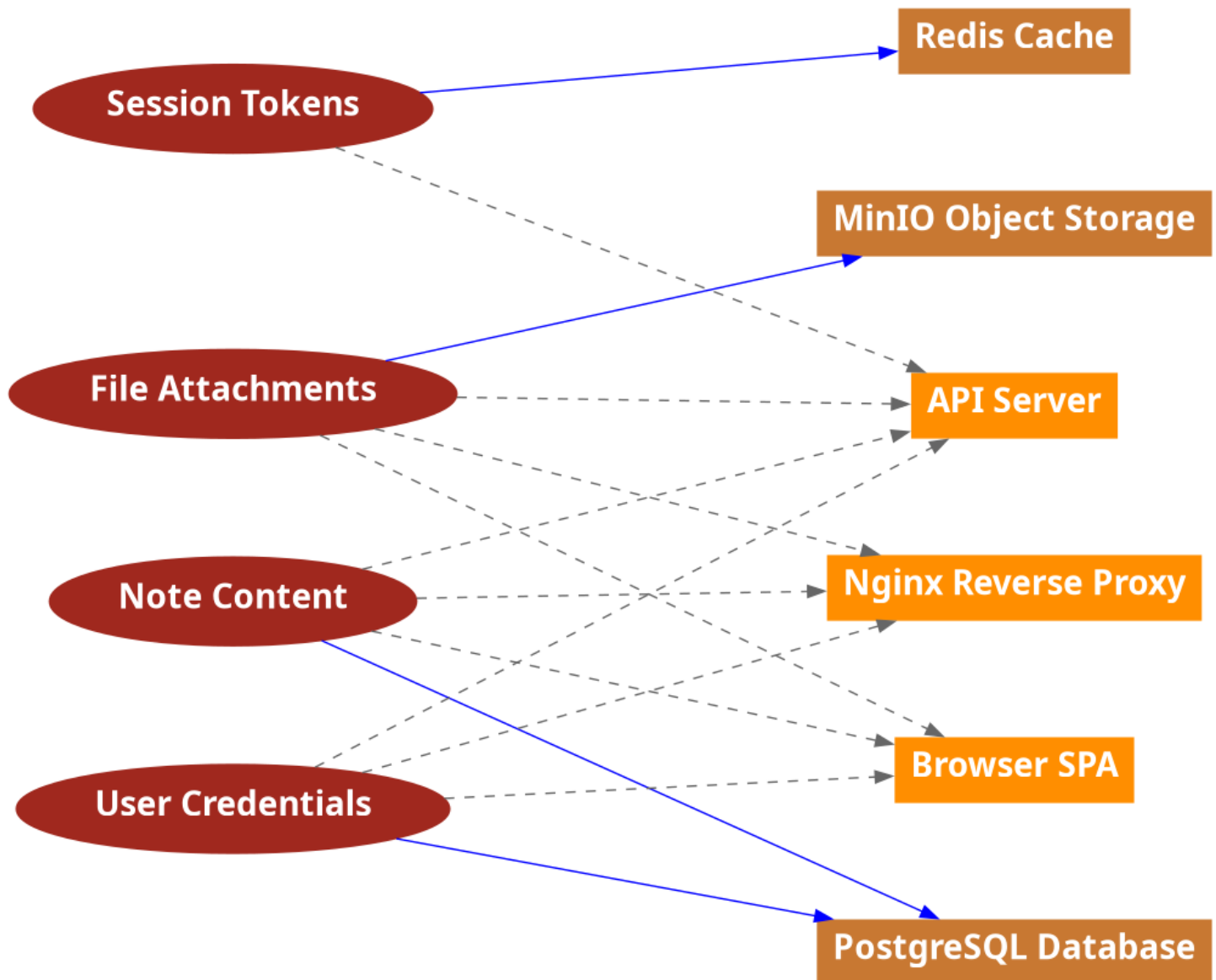
S3-compatible object store for file attachments. INTENTIONAL MISCONFIGURATION: Uses default minioadmin/minioadmin credentials (visible in docker-compose.yml) and stores files without encryption at rest. HTTP-only (no TLS) within the Docker network.

Nginx Reverse Proxy: RAA 2%

Nginx terminates TLS and forwards all API traffic to the Express server over plain HTTP (port 3000). This is the DMZ entry point.

Data Mapping

The following diagram was generated by Threagile based on the model input and gives a high-level distribution of data assets across technical assets. The color matches the identified data breach probability and risk level (see the "Data Breach Probabilities" chapter for more details). A solid line stands for *data is stored by the asset* and a dashed one means *data is processed by the asset*. For a full high-resolution version of this diagram please refer to the PNG image file alongside this report.



Out-of-Scope Assets: 0 Assets

This chapter lists all technical assets that have been defined as out-of-scope. Each one should be checked in the model whether it should better be included in the overall risk analysis:

Technical asset paragraphs are clickable and link to the corresponding chapter.

No technical assets have been defined as out-of-scope.

Potential Model Failures: 0 / 0 Risks

This chapter lists potential model failures where not all relevant assets have been modeled or the model might itself contain inconsistencies. Each potential model failure should be checked in the model against the architecture design:

Risk finding paragraphs are clickable and link to the corresponding chapter.

No potential model failures have been identified.

Questions: 0 / 0 Questions

This chapter lists custom questions that arose during the threat modeling process.

No custom questions arose during the threat modeling process.

Identified Risks by Vulnerability category

In total **12 potential risks** have been identified during the threat modeling process of which **0 are rated as critical, 0 as high, 6 as elevated, 6 as medium, and 0 as low.**

These risks are distributed across **5 vulnerability categories**. The following sub-chapters of this section describe each identified risk category.

Data Disclosure - Personal Data Transmitted Over Unencrypted Channel: 2

Description (Information Disclosure): [CWE 319](#)

Personal data in transit over unencrypted communication links (plain HTTP, unencrypted database protocols, etc.) is exposed to network observers. GDPR Article 32 requires appropriate technical measures including encryption in transit.

Impact

Exposure of personal data to eavesdroppers, potential data breach notification obligations under GDPR Article 33, and significant regulatory penalties.

Detection Logic

In-scope technical assets that process PII data assets AND have at least one outgoing communication link that is unencrypted and not VPN-protected.

Risk Rating

High — unencrypted PII in transit is a direct GDPR Article 32 violation.

False Positives

Assets that process PII but only transmit it over TLS or VPN links; verify with the full threat model review.

Mitigation (Architecture): Encrypt all links that carry personal data

Migrate all communication links carrying PII data assets to TLS 1.2+ (preferably TLS 1.3). For internal service-to-service communication, consider mutual TLS (mTLS).

ASVS Chapter: [V9 - Communication Verification Requirements](#)

Cheat Sheet: [Transport Layer Security Cheat Sheet](#)

Check

Are all communication links carrying personal data encrypted in transit?

Risk Findings

The risk **Data Disclosure - Personal Data Transmitted Over Unencrypted Channel** was found **2 times** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Data Disclosure: API Server processes personal data and has an unencrypted outgoing communication link: Exploitation likelihood is *Likely with High* impact.

[data-disclosure-pii-unencrypted-link@api-server](#)

[In Progress](#) 2026-04-25 Security Team VAULT-117

The API server communicates with PostgreSQL, Redis, and MinIO over plaintext connections within backend-net. TLS for all internal database connections is planned post-launch in VAULT-117. MinIO credential rotation is tracked in VAULT-110 (blocker).

Data Disclosure: Nginx Reverse Proxy processes personal data and has an unencrypted outgoing communication link: Exploitation likelihood is *Likely with High* impact.

[data-disclosure-pii-unencrypted-link@nginx-proxy](#)

[In Progress](#) 2026-04-18 Security Team VAULT-102

Duplicate of VAULT-102 (Nginx.API plaintext link). Resolved when mTLS migration completes in sprint 22. LINDDUN data-disclosure finding is tracked under the same remediation work.

Detectability - PII Flows Without Audit Logging: 2 / 2 Risks

Description (Repudiation): [CWE 778](#)

Communication links that carry personal data without audit logging enabled mean that access to and use of personal data cannot be detected or reviewed after the fact. GDPR Article 5(2) requires demonstrable accountability.

Impact

Inability to detect unauthorized access to personal data, failure to meet GDPR accountability obligations, and potential inability to meet breach notification deadlines.

Detection Logic

In-scope technical assets that process PII AND have at least one outgoing link without audit logging enabled.

Risk Rating

Medium severity baseline; elevated if the data includes sensitive categories.

False Positives

Fully tokenised flows, or flows covered by audit logging at a gateway layer.

Mitigation (Operations): Enable audit logging on all links carrying personal data

Set `audit_logged` to true on every communication link that transmits PII data assets. Store logs in a tamper-evident system separate from the application.

ASVS Chapter: [V7 - Error Handling and Logging Verification Requirements](#)

Cheat Sheet: [Logging Cheat Sheet](#)

Check

Are all communication links that carry personal data audit-logged?

Risk Findings

The risk **Detectability - PII Flows Without Audit Logging** was found **2 times** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Detectability: Nginx Reverse Proxy processes PII and has communication links without audit logging: Exploitation likelihood is *Likely with Medium* impact.

[detecting-no-audit-logging@nginx-proxy](#)

Accepted

2026-04-25

Security Team

VAULT-115

Nginx access.log captures all incoming requests (IP, URL, status code, response size). Individual API-level audit events are handled by the API server. The Nginx.API internal hop has no separate audit log; this is accepted as the TLS-termination boundary log is sufficient for DMZ-level audit requirements.

Detectability: API Server processes PII and has communication links without audit logging: Exploitation likelihood is *Likely with Medium* impact.

[detecting-no-audit-logging@api-server](#)

In Progress

2026-04-25

Security Team

VAULT-116

Structured request/response audit logging (Morgan + Winston) is implemented for authenticated endpoints but coverage is incomplete for internal data-access events. Full audit trail covering all PII-processing operations is tracked in VAULT-116. Target: sprint 23.

Non-Repudiation - PII or Auth Tokens Accessible in Browser-Side Storage

Description (Information Disclosure): [CWE 922](#)

Browser-based clients (SPAs, web apps) that process personal data or authentication tokens typically persist them in `localStorage` or `sessionStorage`. This browser-accessible storage is readable by any JavaScript running in the same origin – including injected scripts. Without `HttpOnly` cookies or a strict Content-Security-Policy, the stored tokens and PII are one XSS payload away from full exfiltration. From a LINDDUN perspective this enables Non-Repudiation attacks: an adversary who steals a token can act as the victim, making it impossible to distinguish attacker actions from legitimate user actions in audit logs.

Impact

Stolen session tokens allow account takeover and impersonation. The original user cannot repudiate actions performed by the attacker. Stolen PII violates GDPR data minimisation and storage limitation principles.

Detection Logic

In-scope technical assets with browser (client) technology that process PII data assets and are not tagged with `has-httponly-session`.

Risk Rating

Medium baseline. Elevated when tokens have long TTL (>1 hour) or when no CSP is configured on the serving origin.

False Positives

Applications that exclusively use `HttpOnly` cookies for session management and do not store any PII in JavaScript-accessible storage. Tag the asset `has-httponly-session` to suppress this finding once verified.

Mitigation (Development): Move session tokens to `HttpOnly` cookies; apply Content-Security-Policy

Replace `localStorage/sessionStorage` token storage with `HttpOnly`, `Secure`, `SameSite=Strict` cookies. Cookies with the `HttpOnly` flag are inaccessible to JavaScript, eliminating the XSS token-theft vector. Deploy a strict Content-Security-Policy to limit damage from any residual XSS. Tag the asset `has-httponly-session` once deployed.

ASVS Chapter: [V3 - Session Management Verification Requirements](#)
Cheat Sheet: [HTML5 Security Cheat Sheet](#)

Check

Are authentication tokens stored in HttpOnly cookies rather than localStorage? Is a Content-Security-Policy header present on all pages served to this browser client?

Risk Findings

The risk **Non-Repudiation - PII or Auth Tokens Accessible in Browser-Side Storage** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

PII in Client-Side Storage: browser asset **Browser SPA** processes personal data that may be stored in JavaScript-accessible browser storage: Exploitation likelihood is *Likely* with *Medium* impact.

pii-client-side-storage@browser-spa

Unchecked

Unawareness - PII Processed Without a Consent Management Component

Description (Information Disclosure): [CWE 359](#)

When a system processes personal data from end users but has no consent-management technology in the architecture, data subjects are likely unaware of the nature and extent of processing. GDPR Articles 13 and 14 require transparent disclosure.

Impact

Data subjects cannot exercise GDPR rights. Regulatory investigation risk and class-action exposure in jurisdictions with private right of action.

Detection Logic

In-scope user-facing technical assets that process PII data assets where no other asset carries a `consent_collector` technology attribute.

Risk Rating

Medium baseline; elevated for consumer-facing applications or special-category data.

False Positives

B2B systems under a contract lawful basis where consent is not applicable.

Mitigation (Architecture): Add a consent management technical asset to the architecture

Introduce a consent-manager (tagged with technology `consent-manager`) to capture, store, and honour data-subject preferences.

ASVS Chapter: [V8 - Data Protection Verification Requirements](#)

Cheat Sheet: [Logging_Cheat_Sheet](#)

Check

Does the architecture include a consent management component when processing PII?

Risk Findings

The risk **Unawareness - PII Processed Without a Consent Management Component** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Unawareness: Browser SPA processes end-user PII but no consent management component is present: Exploitation likelihood is *Likely* with *Medium* impact.

[unawareness-no-consent-technology@browser-spa](#)

[In Progress](#)

2026-04-25

Privacy Team

VAULT-118

A consent management platform (CMP) is being evaluated (OneTrust / Osano). In the interim, the privacy policy is displayed at registration and users explicitly accept terms before account creation. Formal CMP integration is planned for Q3 2026.

Linkability - Same PII Data Asset Processed Across Multiple Trust Boundaries

Description (Information Disclosure): [CWE 359](#)

When the same personal-data asset is processed by technical assets in two or more different trust boundaries, an attacker who compromises any one boundary gains linkability across all others, enabling cross-context profiling.

Impact

Aggregation of personal data enables profiling, re-identification, and violations of GDPR data minimisation and purpose limitation principles (Articles 5(1)(b) and 5(1)(c)).

Detection Logic

Technical assets that process PII data assets that also appear in assets in at least one other trust boundary.

Risk Rating

Medium baseline; elevated for sensitive categories or high-quantity data.

False Positives

Internal service meshes within a single logical zone modelled as separate trust boundaries.

Mitigation (Architecture): Apply data minimisation and per-context pseudonymisation

Use per-context pseudonyms or pairwise identifiers so the same natural person cannot be linked across trust boundaries.

ASVS Chapter: [V8 - Data Protection Verification Requirements](#)

Cheat Sheet: [Attack_Surface_Analysis_Cheat_Sheet](#)

Check

Does each PII data asset appear in assets across more than one trust boundary?

Risk Findings

The risk **Linkability - Same PII Data Asset Processed Across Multiple Trust Boundaries** was found **6 times** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Linkability: API Server processes a PII data asset also flowing into another trust boundary: Exploitation likelihood is *Unlikely with Medium impact*.

[linking-pii-multi-boundary@api-server](#)

Accepted 2026-04-25 Security Team VAULT-119

The API server bridges frontend-net and backend-net by architectural necessity — it is the sole legitimate data path between the two networks. Cross-boundary PII flow is an inherent design characteristic, not a misconfiguration. Mitigated by authentication + authorization enforcement at the API layer.

Linkability: Browser SPA processes a PII data asset also flowing into another trust boundary: Exploitation likelihood is *Unlikely with Medium impact*.

[linking-pii-multi-boundary@browser-spa](#)

Accepted 2026-04-25 Security Team VAULT-119

The Browser SPA processes user-credentials and note-content across the Internet and DMZ boundaries by design (user-facing client). The risk is inherent to the SPA architecture; mitigated by HTTPS-only transport and short-lived session tokens.

Linkability: MinIO Object Storage processes a PII data asset also flowing into another trust boundary: Exploitation likelihood is *Unlikely with Medium impact*.

[linking-pii-multi-boundary@minio-storage](#)

Accepted 2026-04-25 Security Team VAULT-119

File attachments uploaded via the Internet are stored in the Data Tier. Cross-boundary flow is by design. VAULT-110 (credential rotation + SSE) addresses the high-severity storage risk; the linkability finding is accepted as an inherent architectural property.

Linkability: Nginx Reverse Proxy processes a PII data asset also flowing into another trust boundary: Exploitation likelihood is *Unlikely with Medium impact*.

[linking-pii-multi-boundary@nginx-proxy](#)

Accepted 2026-04-25 Security Team VAULT-119

Nginx is the TLS-termination proxy and must bridge Internet and DMZ by design. Cross-boundary PII flow is intentional and unavoidable for this component.

Linkability: PostgreSQL Database processes a PII data asset also flowing into another trust boundary: Exploitation likelihood is *Unlikely with Medium impact*.

[linking-pii-multi-boundary@postgresql-db](#)

Accepted 2026-04-25 Security Team VAULT-119

PostgreSQL stores credentials and note content that originate from multiple trust boundaries (Internet . DMZ . App Network . Data Tier). This is inherent to the data flow by design. Risk is accepted; mitigated by parameterized queries and authentication-only access via the API.

Linkability: Redis Cache processes a PII data asset also flowing into another trust boundary: Exploitation likelihood is *Unlikely* with *Medium* impact.

linking-pii-multi-boundary@redis-cache

Accepted

2026-04-25 Security Team

VAULT-119

Session identifiers originate from users across the Internet boundary. Storage in Redis within the Data Tier is unavoidable. Mitigated by short TTL (15 minutes), revocation list, and password-protected access.

Identified Risks by Technical Asset

In total **12 potential risks** have been identified during the threat modeling process of which **0 are rated as critical, 0 as high, 6 as elevated, 6 as medium, and 0 as low.**

These risks are distributed across **6 in-scope technical assets**. The following sub-chapters of this section describe each identified risk grouped by technical asset. The RAA value of a technical asset is the calculated "Relative Attacker Attractiveness" value in percent.

API Server: 3 / 3 Risks

Description

Node.js/Express REST API. Handles authentication (JWT/bcrypt), CRUD on notes, file uploads to MinIO. Bridges the frontend and backend networks. Single most security-critical component — compromise equals full data access.

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Data Disclosure: API Server processes personal data and has an unencrypted outgoing communication link: Exploitation likelihood is *Likely* with *High* impact.

[data-disclosure-pii-unencrypted-link@api-server](#)

[In Progress](#)

2026-04-25

Security Team

VAULT-117

The API server communicates with PostgreSQL, Redis, and MinIO over plaintext connections within backend-net. TLS for all internal database connections is planned post-launch in VAULT-117. MinIO credential rotation is tracked in VAULT-110 (blocker).

Detectability: API Server processes PII and has communication links without audit logging: Exploitation likelihood is *Likely* with *Medium* impact.

[detecting-no-audit-logging@api-server](#)

[In Progress](#)

2026-04-25

Security Team

VAULT-116

Structured request/response audit logging (Morgan + Winston) is implemented for authenticated endpoints but coverage is incomplete for internal data-access events. Full audit trail covering all PII-processing operations is tracked in VAULT-116. Target: sprint 23.

Medium Risk Severity

Linkability: API Server processes a PII data asset also flowing into another trust boundary: Exploitation likelihood is *Unlikely* with *Medium* impact.

[linking-pii-multi-boundary@api-server](#)

[Accepted](#)

2026-04-25

Security Team

VAULT-119

The API server bridges frontend-net and backend-net by architectural necessity — it is the sole legitimate data path between the two networks. Cross-boundary PII flow is an inherent design characteristic, not a misconfiguration. Mitigated by authentication + authorization enforcement at the API layer.

Asset Information

ID:	api-server
Type:	process
Usage:	business
RAA:	82 %

Size:	service
Technology:	web-service-rest
Tags:	express, jwt, nodejs
Internet:	false
Machine:	container
Encryption:	none
Multi-Tenant:	false
Redundant:	false
Custom-Developed:	true
Client by Human:	false
Data Processed:	File Attachments, Note Content, Session Tokens, User Credentials
Data Stored:	none
Formats Accepted:	JSON

Asset Rating

Owner:	VaultNote Team
Confidentiality:	strictly-confidential (rated 5 in scale of 5)
Integrity:	critical (rated 4 in scale of 5)
Availability:	critical (rated 4 in scale of 5)
CIA-Justification:	The API processes all user data. It bridges both Docker networks — a compromised API container can pivot into the internal data tier.

Outgoing Communication Links: 3

Target technical asset names are clickable and link to the corresponding chapter.

Redis Session Store (outgoing)

Session token storage and JWT revocation list. Password-protected (requirepass) but no TLS.

Target:	Redis Cache
Protocol:	nosql-access-protocol
Encrypted:	false
Authentication:	credentials
Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false

IP-Filtered: false
Data Sent: Session Tokens
Data Received: Session Tokens

PostgreSQL Connection (outgoing)

Application-level SQL queries for user auth, notes CRUD. Uses parameterized queries (pg library) to prevent SQL injection. No TLS on the connection — traffic is plaintext within backend-net.

Target: PostgreSQL Database
Protocol: sql-access-protocol
Encrypted: false
Authentication: credentials
Authorization: technical-user
Read-Only: false
Usage: business
Tags: none
VPN: false
IP-Filtered: false
Data Sent: Note Content, User Credentials
Data Received: Note Content, User Credentials

MinIO File Storage (outgoing)

INTENTIONAL MISCONFIGURATION: S3 API calls to MinIO over plain HTTP. Default minioadmin/minioadmin credentials are hardcoded in compose. Any container on backend-net can read all stored files.

Target: MinIO Object Storage
Protocol: http
Encrypted: false
Authentication: credentials
Authorization: technical-user
Read-Only: false
Usage: business
Tags: intentional-misconfiguration
VPN: false
IP-Filtered: false
Data Sent: File Attachments
Data Received: File Attachments

Incoming Communication Links: 1

Source technical asset names are clickable and link to the corresponding chapter.

HTTP to API Server (incoming)

INTENTIONAL MISCONFIGURATION: Traffic between Nginx and the API server uses plaintext HTTP. An attacker with access to the Docker network (container escape, compromised sidecar) can intercept credentials, session tokens, and note content in transit.

Source:	Nginx Reverse Proxy
Protocol:	http
Encrypted:	false
Authentication:	none
Authorization:	none
Read-Only:	false
Usage:	business
Tags:	intentional-misconfiguration
VPN:	false
IP-Filtered:	false
Data Received:	File Attachments, Note Content, User Credentials
Data Sent:	File Attachments, Note Content

Browser SPA: 3 / 3 Risks

Description

React Single Page Application served from Nginx. Users authenticate, manage notes, and upload files through this interface.

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

PII in Client-Side Storage: browser asset **Browser SPA** processes personal data that may be stored in JavaScript-accessible browser storage: Exploitation likelihood is *Likely* with *Medium* impact.

[pii-client-side-storage@browser-spa](#)

Unchecked

Unawareness: Browser SPA processes end-user PII but no consent management component is present: Exploitation likelihood is *Likely* with *Medium* impact.

[unawareness-no-consent-technology@browser-spa](#)

In Progress

2026-04-25

Privacy Team

VAULT-118

A consent management platform (CMP) is being evaluated (OneTrust / Osano). In the interim, the privacy policy is displayed at registration and users explicitly accept terms before account creation. Formal CMP integration is planned for Q3 2026.

Medium Risk Severity

Linkability: Browser SPA processes a PII data asset also flowing into another trust boundary: Exploitation likelihood is *Unlikely* with *Medium* impact.

[linking-pii-multi-boundary@browser-spa](#)

Accepted

2026-04-25

Security Team

VAULT-119

The Browser SPA processes user-credentials and note-content across the Internet and DMZ boundaries by design (user-facing client). The risk is inherent to the SPA architecture; mitigated by HTTPS-only transport and short-lived session tokens.

Asset Information

ID:	browser-spa
Type:	external-entity
Usage:	business
RAA:	54 %
Size:	application
Technology:	browser

Tags:	react, spa
Internet:	true
Machine:	physical
Encryption:	none
Multi-Tenant:	false
Redundant:	false
Custom-Developed:	true
Client by Human:	true
Data Processed:	File Attachments, Note Content, User Credentials
Data Stored:	none
Formats Accepted:	JSON

Asset Rating

Owner:	End Users
Confidentiality:	strictly-confidential (rated 5 in scale of 5)
Integrity:	critical (rated 4 in scale of 5)
Availability:	operational (rated 2 in scale of 5)
CIA-Justification:	Client-side code is public; the trust boundary here is user data entered into the browser. XSS would allow an attacker to exfiltrate session tokens.

Outgoing Communication Links: 1

Target technical asset names are clickable and link to the corresponding chapter.

HTTPS to Nginx (outgoing)

User-initiated HTTPS requests carrying credentials (login) and note content (create/edit). This is the only encrypted link in the chain.

Target:	Nginx Reverse Proxy
Protocol:	https
Encrypted:	true
Authentication:	credentials
Authorization:	end-user-identity-propagation
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false

Data Sent: File Attachments, Note Content, User Credentials

Data Received: File Attachments, Note Content

Nginx Reverse Proxy: 3 / 3 Risks

Description

Nginx terminates TLS and forwards all API traffic to the Express server over plain HTTP (port 3000). This is the DMZ entry point.

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Detectability: Nginx Reverse Proxy processes PII and has communication links without audit logging: Exploitation likelihood is *Likely* with *Medium* impact.

[detecting-no-audit-logging@nginx-proxy](#)

Accepted

2026-04-25

Security Team

VAULT-115

Nginx access.log captures all incoming requests (IP, URL, status code, response size). Individual API-level audit events are handled by the API server. The Nginx.API internal hop has no separate audit log; this is accepted as the TLS-termination boundary log is sufficient for DMZ-level audit requirements.

Data Disclosure: Nginx Reverse Proxy processes personal data and has an unencrypted outgoing communication link: Exploitation likelihood is *Likely* with *High* impact.

[data-disclosure-pii-unencrypted-link@nginx-proxy](#)

In Progress

2026-04-18

Security Team

VAULT-102

Duplicate of VAULT-102 (Nginx.API plaintext link). Resolved when mTLS migration completes in sprint 22. LINDDUN data-disclosure finding is tracked under the same remediation work.

Medium Risk Severity

Linkability: Nginx Reverse Proxy processes a PII data asset also flowing into another trust boundary: Exploitation likelihood is *Unlikely* with *Medium* impact.

[linking-pii-multi-boundary@nginx-proxy](#)

Accepted

2026-04-25

Security Team

VAULT-119

Nginx is the TLS-termination proxy and must bridge Internet and DMZ by design. Cross-boundary PII flow is intentional and unavoidable for this component.

Asset Information

ID:	nginx-proxy
Type:	process
Usage:	business
RAA:	2 %
Size:	service
Technology:	reverse-proxy

Tags:	nginx, tls-termination
Internet:	false
Machine:	container
Encryption:	none
Multi-Tenant:	false
Redundant:	false
Custom-Developed:	false
Client by Human:	false
Data Processed:	File Attachments, Note Content, User Credentials
Data Stored:	none
Formats Accepted:	JSON

Asset Rating

Owner:	VaultNote Team
Confidentiality:	strictly-confidential (rated 5 in scale of 5)
Integrity:	critical (rated 4 in scale of 5)
Availability:	critical (rated 4 in scale of 5)
CIA-Justification:	Nginx is the single external entry point. Its compromise exposes all downstream services. Availability is critical — outage = full service outage.

Outgoing Communication Links: 1

Target technical asset names are clickable and link to the corresponding chapter.

HTTP to API Server (outgoing)

INTENTIONAL MISCONFIGURATION: Traffic between Nginx and the API server uses plaintext HTTP. An attacker with access to the Docker network (container escape, compromised sidecar) can intercept credentials, session tokens, and note content in transit.

Target:	API Server
Protocol:	http
Encrypted:	false
Authentication:	none
Authorization:	none
Read-Only:	false
Usage:	business
Tags:	intentional-misconfiguration
VPN:	false

IP-Filtered:	false
Data Sent:	File Attachments, Note Content, User Credentials
Data Received:	File Attachments, Note Content

Incoming Communication Links: 1

Source technical asset names are clickable and link to the corresponding chapter.

HTTPS to Nginx (incoming)

User-initiated HTTPS requests carrying credentials (login) and note content (create/edit). This is the only encrypted link in the chain.

Source:	Browser SPA
Protocol:	https
Encrypted:	true
Authentication:	credentials
Authorization:	end-user-identity-propagation
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Received:	File Attachments, Note Content, User Credentials
Data Sent:	File Attachments, Note Content

MinIO Object Storage: 1 / 1 Risk

Description

S3-compatible object store for file attachments. INTENTIONAL MISCONFIGURATION: Uses default minioadmin/minioadmin credentials (visible in docker-compose.yml) and stores files without encryption at rest. HTTP-only (no TLS) within the Docker network.

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Linkability: MinIO Object Storage processes a PII data asset also flowing into another trust boundary: Exploitation likelihood is *Unlikely* with *Medium* impact.

[linking-pii-multi-boundary@minio-storage](#)

Accepted

2026-04-25

Security Team

VAULT-119

File attachments uploaded via the Internet are stored in the Data Tier. Cross-boundary flow is by design. VAULT-110 (credential rotation + SSE) addresses the high-severity storage risk; the linkability finding is accepted as an inherent architectural property.

Asset Information

ID:	minio-storage
Type:	datastore
Usage:	business
RAA:	39 %
Size:	service
Technology:	file-server
Tags:	intentional-misconfiguration, minio, object-storage, s3
Internet:	false
Machine:	container
Encryption:	none
Multi-Tenant:	false
Redundant:	false
Custom-Developed:	false
Client by Human:	false
Data Processed:	File Attachments
Data Stored:	File Attachments
Formats Accepted:	File

Asset Rating

Owner:	VaultNote Team	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	critical	(rated 4 in scale of 5)
Availability:	operational	(rated 2 in scale of 5)
CIA-Justification:	Stores user file uploads which may contain sensitive documents. Default credentials + no encryption = trivial exfiltration by any process on backend-net.	

Incoming Communication Links: 1

Source technical asset names are clickable and link to the corresponding chapter.

MinIO File Storage (incoming)

INTENTIONAL MISCONFIGURATION: S3 API calls to MinIO over plain HTTP. Default minioadmin/minioadmin credentials are hardcoded in compose. Any container on backend-net can read all stored files.

Source:	API Server
Protocol:	http
Encrypted:	false
Authentication:	credentials
Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	intentional-misconfiguration
VPN:	false
IP-Filtered:	false
Data Received:	File Attachments
Data Sent:	File Attachments

PostgreSQL Database: 1 / 1 Risk

Description

Primary relational datastore. Contains users table (email + bcrypt password hash), notes table (title + content), and attachments metadata. INTENTIONAL MISCONFIGURATION: No encryption at rest (encryption: none).

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Linkability: PostgreSQL Database processes a PII data asset also flowing into another trust boundary: Exploitation likelihood is *Unlikely* with *Medium* impact.

[linking-pii-multi-boundary@postgresql-db](#)

Accepted

2026-04-25

Security Team

VAULT-119

PostgreSQL stores credentials and note content that originate from multiple trust boundaries (Internet . DMZ . App Network . Data Tier). This is inherent to the data flow by design. Risk is accepted; mitigated by parameterized queries and authentication-only access via the API.

Asset Information

ID:	postgresql-db
Type:	datastore
Usage:	business
RAA:	100 %
Size:	service
Technology:	database
Tags:	postgresql, relational
Internet:	false
Machine:	container
Encryption:	none
Multi-Tenant:	false
Redundant:	false
Custom-Developed:	false
Client by Human:	false
Data Processed:	Note Content, User Credentials
Data Stored:	Note Content, User Credentials
Formats Accepted:	JSON

Asset Rating

Owner:	VaultNote Team	
Confidentiality:	strictly-confidential	(rated 5 in scale of 5)
Integrity:	critical	(rated 4 in scale of 5)
Availability:	critical	(rated 4 in scale of 5)
CIA-Justification:	Holds all user PII (email, hashed passwords) and all note content. Strictly confidential — unencrypted disk access exposes all data.	

Incoming Communication Links: 1

Source technical asset names are clickable and link to the corresponding chapter.

PostgreSQL Connection (incoming)

Application-level SQL queries for user auth, notes CRUD. Uses parameterized queries (pg library) to prevent SQL injection. No TLS on the connection — traffic is plaintext within backend-net.

Source:	API Server
Protocol:	sql-access-protocol
Encrypted:	false
Authentication:	credentials
Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Received:	Note Content, User Credentials
Data Sent:	Note Content, User Credentials

Redis Cache: 1 / 1 Risk

Description

In-memory store used as session store and JWT revocation list. INTENTIONAL MISCONFIGURATION: No encryption at rest. If Redis persistence is enabled and the RDB file is exfiltrated, session tokens are exposed.

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Linkability: Redis Cache processes a PII data asset also flowing into another trust boundary: Exploitation likelihood is *Unlikely* with *Medium* impact.

[linking-pii-multi-boundary@redis-cache](#)

Accepted

2026-04-25

Security Team

VAULT-119

Session identifiers originate from users across the Internet boundary. Storage in Redis within the Data Tier is unavoidable. Mitigated by short TTL (15 minutes), revocation list, and password-protected access.

Asset Information

ID:	redis-cache
Type:	datastore
Usage:	business
RAA:	40 %
Size:	component
Technology:	database
Tags:	cache, redis, session-store
Internet:	false
Machine:	container
Encryption:	none
Multi-Tenant:	false
Redundant:	false
Custom-Developed:	false
Client by Human:	false
Data Processed:	Session Tokens
Data Stored:	Session Tokens
Formats Accepted:	none of the special data formats accepted

Asset Rating

Owner:	VaultNote Team	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	critical	(rated 4 in scale of 5)
Availability:	important	(rated 3 in scale of 5)
CIA-Justification:	Session token exposure enables account takeover. Non-persistent by default but the container volume could persist RDB snapshots.	

Incoming Communication Links: 1

Source technical asset names are clickable and link to the corresponding chapter.

Redis Session Store (incoming)

Session token storage and JWT revocation list. Password-protected (requirepass) but no TLS.

Source:	API Server
Protocol:	nosql-access-protocol
Encrypted:	false
Authentication:	credentials
Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Received:	Session Tokens
Data Sent:	Session Tokens

Identified Data Breach Probabilities by Data Asset

In total **12 potential risks** have been identified during the threat modeling process of which **0 are rated as critical, 0 as high, 6 as elevated, 6 as medium, and 0 as low.**

These risks are distributed across **4 data assets**. The following sub-chapters of this section describe the derived data breach probabilities grouped by data asset.

Technical asset names and risk IDs are clickable and link to the corresponding chapter.

File Attachments: 10 / 10 Risks

Binary file uploads attached to notes. May include documents, images, or other sensitive files depending on note usage.

ID:	file-attachments		
Usage:	business		
Quantity:	many		
Tags:	none		
Origin:	customer		
Owner:	VaultNote Team		
Confidentiality:	confidential	(rated 4 in scale of 5)	
Integrity:	critical	(rated 4 in scale of 5)	
Availability:	operational	(rated 2 in scale of 5)	
CIA-Justification:	Files may contain sensitive documents. Integrity is critical because tampered attachments corrupt evidence or business records. MinIO's default credentials (minioadmin) make all stored files accessible to anyone on the network — intentional misconfiguration for demo purposes.		
Processed by:	API Server, Browser SPA, MinIO Object Storage, Nginx Reverse Proxy		
Stored by:	MinIO Object Storage		
Sent via:	MinIO File Storage, HTTPS to Nginx, HTTP to API Server		
Received via:	MinIO File Storage, HTTPS to Nginx, HTTP to API Server		
Data Breach:	probable		
Data Breach Risks:	This data asset has data breach potential because of 10 remaining risksStr:		
	Probable: detecting-no-audit-logging@nginx-proxy		
	Probable: data-disclosure-pii-unencrypted-link@api-server		
	Probable: data-disclosure-pii-unencrypted-link@nginx-proxy		
	Probable: detecting-no-audit-logging@api-server		
	Possible: pii-client-side-storage@browser-spa		
	Improbable: linking-pii-multi-boundary@api-server		
	Improbable: linking-pii-multi-boundary@browser-spa		
	Improbable: linking-pii-multi-boundary@minio-storage		
	Improbable: linking-pii-multi-boundary@nginx-proxy		
	Improbable: unawareness-no-consent-technology@browser-spa		

Note Content: 10 / 10 Risks

User-authored note text — may include personal, financial, or health information depending on how users employ the application.

ID:	note-content	
Usage:	business	
Quantity:	many	
Tags:	none	
Origin:	customer	
Owner:	VaultNote Team	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	critical	(rated 4 in scale of 5)
Availability:	operational	(rated 2 in scale of 5)
CIA-Justification:	Notes may contain highly sensitive personal information. Integrity is critical because corrupted notes lose user trust.	
Processed by:	API Server, Browser SPA, Nginx Reverse Proxy, PostgreSQL Database	
Stored by:	PostgreSQL Database	
Sent via:	PostgreSQL Connection, HTTPS to Nginx, HTTP to API Server	
Received via:	PostgreSQL Connection, HTTPS to Nginx, HTTP to API Server	
Data Breach:	probable	
Data Breach Risks:	This data asset has data breach potential because of 10 remaining risksStr:	
	Probable: detecting-no-audit-logging@nginx-proxy	
	Probable: data-disclosure-pii-unencrypted-link@api-server	
	Probable: data-disclosure-pii-unencrypted-link@nginx-proxy	
	Probable: detecting-no-audit-logging@api-server	
	Possible: pii-client-side-storage@browser-spa	
	Improbable: linking-pii-multi-boundary@api-server	
	Improbable: linking-pii-multi-boundary@browser-spa	
	Improbable: linking-pii-multi-boundary@nginx-proxy	
	Improbable: linking-pii-multi-boundary@postgresql-db	
	Improbable: unawareness-no-consent-technology@browser-spa	

Session Tokens: 4 / 4 Risks

JWT tokens and Redis session keys used to maintain authenticated state. Theft allows session hijacking without knowing the user's password.

ID:	session-tokens	
Usage:	business	
Quantity:	many	
Tags:	none	
Origin:	internal	
Owner:	VaultNote Team	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	critical	(rated 4 in scale of 5)
Availability:	operational	(rated 2 in scale of 5)
CIA-Justification:	Session token compromise enables full session hijacking. Short TTLs and revocation lists mitigate but do not eliminate the risk.	
Processed by:	API Server, Redis Cache	
Stored by:	Redis Cache	
Sent via:	Redis Session Store	
Received via:	Redis Session Store	
Data Breach:	probable	

Data Breach Risks: This data asset has data breach potential because of 4 remaining risksStr:

Probable: data-disclosure-pii-unencrypted-link@api-server

Probable: detecting-no-audit-logging@api-server

Improbable: linking-pii-multi-boundary@api-server

Improbable: linking-pii-multi-boundary@redis-cache

User Credentials: 10 / 10 Risks

Email addresses and bcrypt-hashed passwords used for authentication. Compromise allows full account takeover.

ID:	user-credentials
Usage:	business
Quantity:	many
Tags:	none
Origin:	customer
Owner:	VaultNote Team
Confidentiality:	strictly-confidential (rated 5 in scale of 5)
Integrity:	critical (rated 4 in scale of 5)
Availability:	operational (rated 2 in scale of 5)
CIA-Justification:	Credentials grant full account access. A breach leaks all users' identities and enables account takeover across every note and attachment.
Processed by:	API Server, Browser SPA, Nginx Reverse Proxy, PostgreSQL Database
Stored by:	PostgreSQL Database
Sent via:	PostgreSQL Connection, HTTPS to Nginx, HTTP to API Server
Received via:	PostgreSQL Connection

Data Breach: **probable**

Data Breach Risks: This data asset has data breach potential because of 10 remaining risksStr:

Probable: detecting-no-audit-logging@nginx-proxy

Probable: data-disclosure-pii-unencrypted-link@api-server

Probable: data-disclosure-pii-unencrypted-link@nginx-proxy

Probable: detecting-no-audit-logging@api-server

Possible: pii-client-side-storage@browser-spa

Improbable: linking-pii-multi-boundary@api-server

Improbable: linking-pii-multi-boundary@browser-spa

Improbable: linking-pii-multi-boundary@nginx-proxy

Improbable: linking-pii-multi-boundary@postgresql-db

Improbable: unawareness-no-consent-technology@browser-spa

Trust Boundaries

In total **4 trust boundaries** have been modeled during the threat modeling process.

Application Network

Internal Docker bridge network (frontend-net). Contains the API server which is reachable from Nginx but also bridges into backend-net.

ID: application-network
Type: network-on-prem
Tags: none
Assets inside: API Server
Boundaries nested: none

DMZ

Demilitarized zone containing the Nginx reverse proxy. Accessible from the internet but isolated from the application and data tiers.

ID: dmz
Type: network-on-prem
Tags: none
Assets inside: Nginx Reverse Proxy
Boundaries nested: none

Data Tier

Internal Docker bridge network (backend-net, marked internal: true). No external routing. Contains all datastores. The API server has a NIC on this network and acts as the sole legitimate access path.

ID: data-tier
Type: network-on-prem
Tags: none
Assets inside: MinIO Object Storage, PostgreSQL Database, Redis Cache
Boundaries nested: none

Internet

Untrusted external network. All traffic from this zone must cross the Nginx TLS termination point before entering the DMZ.

ID: internet
Type: [network-on-prem](#)
Tags: none
Assets inside: Browser SPA
Boundaries nested: none

Shared Runtimes

In total **1 shared runtime** has been modeled during the threat modeling process.

Docker Host

All containers run on the same Docker host. A container escape or privileged container could access the host filesystem including Docker socket and database volumes.

ID:	docker-host
Tags:	container-runtime, docker
Assets running:	Nginx Reverse Proxy, API Server, PostgreSQL Database, Redis Cache, MinIO Object Storage

Risk Rules Checked by Threagile

Threagile Version: 1.0.0

Threagile Build Timestamp:

Threagile Execution Timestamp: 20260524151524

Model Filename: /home/coder221/Desktop/coding/Threat-model/threagile/threagile.yaml

Model Hash (SHA256): d7bfa142abb73e5d3cd46eac265cb228675b53c92a8d976eddf1abb34b52c1d1

Threagile (see <https://threagile.io> for more details) is an open-source toolkit for agile threat modeling, created by Christian Schneider (<https://christian-schneider.net>): It allows to model an architecture with its assets in an agile fashion as a YAML file directly inside the IDE. Upon execution of the Threagile toolkit all standard risk rules (as well as individual custom rules if present) are checked against the architecture model. At the time the Threagile toolkit was executed on the model input file the following risk rules were checked:

Disclaimer

VaultNote Security Team conducted this threat analysis using the open-source Threagile toolkit on the applications and systems that were modeled as of this report's date. Information security threats are continually changing, with new vulnerabilities discovered on a daily basis, and no application can ever be 100% secure no matter how much threat modeling is conducted. It is recommended to execute threat modeling and also penetration testing on a regular basis (for example yearly) to ensure a high ongoing level of security and constantly check for new attack vectors.

This report cannot and does not protect against personal or business loss as the result of use of the applications or systems described. VaultNote Security Team and the Threagile toolkit offers no warranties, representations or legal certifications concerning the applications or systems it tests. All software includes defects: nothing in this document is intended to represent or warrant that threat modeling was complete and without error, nor does this document represent or warrant that the architecture analyzed is suitable to task, free of other defects than reported, fully compliant with any industry standards, or fully compatible with any operating system, hardware, or other application. Threat modeling tries to analyze the modeled architecture without having access to a real working system and thus cannot and does not test the implementation for defects and vulnerabilities. These kinds of checks would only be possible with a separate code review and penetration test against a working system and not via a threat model.

By using the resulting information you agree that VaultNote Security Team and the Threagile toolkit shall be held harmless in any event.

This report is confidential and intended for internal, confidential use by the client. The recipient is obligated to ensure the highly confidential contents are kept secret. The recipient assumes responsibility for further distribution of this document.

In this particular project, a time box approach was used to define the analysis effort. This means that the author allotted a prearranged amount of time to identify and document threats. Because of this, there is no guarantee that all possible threats and risks are discovered. Furthermore, the analysis applies to a snapshot of the current state of the modeled architecture (based on the architecture information provided by the customer) at the examination time.

Report Distribution

Distribution of this report (in full or in part like diagrams or risk findings) requires that this disclaimer as well as the chapter about the Threagile toolkit and method used is kept intact as part of the distributed report or referenced from the distributed parts.